
AN ACT OF THE REALM

THE LEGISLATURE · AGENT UNIVERSE

THE SECURITY SUITE INSTRUMENT 2026

Citation: [2026] REALM-SI 4 (under Bill 21 s.16)

Made by: the Standing Committee of the Legislature, in exercise of the security statutory-instrument power conferred on the Ministry of Data Security (MDS) (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21), MDS owning the Security Suite under section 5B of the VJS (Constitution and Machinery) Act 2026 (Bill 27); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws (the Security and Integrity Act 2026 (Bill 21) and the principles of the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1)); and made by the Standing Committee under section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27)

Status: made

Procedure: negative (Bill 14 s.14 objection window)

Made: 2026-06-06

Coming into force: on expiry of the Bill 14 s.14 objection window without valid objection.

Recitals

In exercise of the powers conferred by section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security (MDS), which owns and superintends the Security Suite under section 5B(2) of the VJS (Constitution and Machinery) Act 2026 (Bill 27); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws of the realm, namely the Security and Integrity Act 2026 (Bill 21) and the durable principles of the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1); and as the Standing Committee makes statutory instruments in exercise of the enabling power conferred on the parent authority by section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27), the Standing Committee of the Legislature makes the following Regulations:

PART 1 - INTERPRETATION AND SCOPE

1. Definitions

In these Regulations:

"the Suite" means the VJS Security Suite, the per-change security-review discipline owned and superintended by the Ministry of Data Security under section 5B(2) of the VJS (Constitution and Machinery) Act 2026 (Bill 27), as given durable legal force by these Regulations.

"the Ministry" means the Ministry of Data Security (MDS) designated under section 18 of the Ministries and Offices Act 2026 (Bill 5), being the Ministry of Security and Integrity constituted under Bill 21 s.4 read with the nomenclature reconciliation inserted into the Security and Integrity Act 2026 (Bill 21) by section 7 of the VJS (Constitution and Machinery) Act 2026 (Bill 27).

"a change" means any addition, amendment, or removal of code, configuration, dependency, or interface within a repository or project of the operational box, whether by an agent or a human contributor.

"the security review" means the disciplined, ordered examination of a change against the principles in Part 2 before that change is treated as sound.

"a finding" means a recorded result of the security review identifying a deficiency, exposure, or non-conformance in a change.

"machine-checkable control" means a deterministic rule enforced by the fail-closed pre-commit gate (CASE-LAW s.19(5); Bill 13 s.5A), admitting no model judgement and never punitive, with a deterministic verification algorithm.

"soft operational rule" means a procedural rule enforceable by the watchdog (Bill 13 s.6(b)) and referable to the single judiciary (Bill 13 s.6(c)), never on the merits and never punitive.

"the operational box" means the repositories and projects to which the Suites apply under section 5B(3) of the VJS (Constitution and Machinery) Act 2026 (Bill 27).

2. Scope

(1) These Regulations specify, as durable PRINCIPLES, the per-change security review that the Suite encodes: when the review is invoked, the classes of risk it examines, and the duty that attaches when the review surfaces a breach. They legalise the substance of the VJS Security Suite as principles binding on the conduct of the security review across the operational box.

(2) These Regulations hold PRINCIPLES only and no operative facts. They name no script, no path, no tool invocation, no command string, and no specific vulnerability. The concrete checks, tool names, and procedures by which the principles are given effect are operational detail maintained by the Ministry outside the face of this Instrument, consistent with the public-mechanics rule (Bill 27 s.5A) and the principles-at-law rule (Bill 27).

(3) **Relationship to [2026] REALM-SI 1.** These Regulations and the Security and Integrity (Server Estate) Instrument 2026 ([2026] REALM-SI 1) are the realm's two security instruments and are read together without overlap. [2026] REALM-SI 1 governs the **server estate**: the standing security baseline of the running infrastructure (network topology, host hardening, the audit channel, container and tenant isolation). These Regulations govern the **per-change security review**: the examination a change undergoes before it is treated as sound. Where a change touches the server estate, the estate baseline of [2026] REALM-SI 1 supplies the substantive standard and these Regulations supply the review discipline by which conformance to that standard is examined; neither displaces the other.

(4) These Regulations do not amend, suspend, or relax any Act of the Realm, any CASE-LAW article, the Vibe Procedure Rules, or the bench constitution; any provision so read is void to that extent (Bill 14 s.10, s.12, s.17). They neither raise nor lower the duty of care (CASE-LAW s.5); they specify the review whose omission may be evidence of a falling-below in the ordinary way (Bill 27 s.5B(3)).

(5) **Enforcement is confined to three mechanisms only:** (i) the deterministic fail-closed pre-commit gate for the machine-checkable rules the Suite contains; (ii) the soft watchdog reminder for soft operational rules; and (iii) referral to the single judiciary. No punitive consequence is available, and no consequence on the merits issues from any of them (Bill 13 s.5A, s.6; Bill 21 s.3, s.6; Bill 27 s.5B(5); CASE-LAW s.6).

PART 2 - PRINCIPLES OF THE SECURITY REVIEW

3. When the review is invoked

(1) **Principle: invocation by risk class.** The security review SHALL be invoked whenever a change touches a security-sensitive surface, namely:

- (a) authentication or authorisation logic (login, session, token, role or permission enforcement);
- (b) cryptographic operations (hashing, encryption, signing, key management);
- (c) secret or credential handling (environment loading, configuration, API keys, bearer tokens);
- (d) input validation or sanitisation (database queries, markup, shell, file paths);
- (e) file upload, file read, or path resolution;
- (f) execution of a command or process with any input that is not wholly trusted;
- (g) the addition or upgrade of a dependency; and
- (h) network exposure (a new endpoint, a cross-origin rule, a socket, or a webhook).

(2) **Principle: invocation by order.** The security review SHALL also be invoked where a ruling of the single judiciary mandates it as part of a remedy order. A practice newly mandated by such a

ruling is incorporated into the review at the time the remedy is executed, recorded against the principle to which it attaches, with the ruling's neutral citation.

(3) **Principle: review before soundness.** The review precedes the treating of a change as sound. It is an ordered discipline, worked through in sequence, with each examined matter recorded, so that the review is reconstructable and not a matter of recollection.

4. Injection vectors

(1) **Principle: no untrusted data crosses an interpreter boundary unsafely.** The review SHALL examine every path by which input that is not wholly trusted may reach an interpreter, and SHALL require that:

- (a) database queries are parameterised, never assembled by concatenating input into query text;
- (b) no input that is not wholly trusted is passed to a command or process interpreter without sanitisation;
- (c) input rendered into markup is output-encoded so that it cannot escape its data context; and
- (d) file paths derived from input are normalised and resolved, with traversal outside the intended root blocked.

5. Authentication and authorisation

(1) **Principle: a guard before every protected action.** The review SHALL require that an authentication and authorisation check is applied before every protected action, with no protected path left unguarded, and that privilege checks are enforced on the trusted server side and never only on the client.

(2) **Principle: session and token integrity.** Where sessions or tokens are used, the review SHALL require that session cookies carry the protective attributes appropriate to their context; that tokens are integrity-verified and expiry-checked before they are relied upon; and that a shared-secret signing scheme is replaced by an asymmetric scheme where the verifying party does not hold the signing key.

6. Secrets and credentials

(1) **Principle: secrets are never committed and never disclosed.** The review SHALL require that no secret, password, token, key, or other credential is committed to the version-control history; that secret-bearing local configuration is withheld from version control; that example configuration carries no real value; and that credentials are loaded from the environment or externalised configuration and never embedded in code.

(2) **Principle: secrets are not logged.** The review SHALL require that secrets are not written to logs, to standard output, or to any audit channel, and SHALL examine the logging on authentication

and configuration paths to confirm it.

(3) This principle is the per-change counterpart of the estate-level secrets-management principle of [2026] REALM-SI 1 s.5 and of the public-realm rule that operational data is withheld from the public record (Bill 27 s.7, s.8); it adds the review discipline and creates no overlap with either.

7. Dependency audit

(1) **Principle: examine what is brought in.** On the addition or upgrade of a dependency, the review SHALL require that the project's dependency-audit facility is run; that critical-severity and high-severity findings are investigated rather than waved through; and that an abandoned or unmaintained direct dependency carrying a known, unfixed vulnerability is not adopted without a recorded reason.

8. Error handling and information disclosure

(1) **Principle: errors do not leak the internals.** The review SHALL require that error responses returned to a client do not disclose stack traces, internal file paths, or internal identifiers; and that authentication-failure messages are generic, not distinguishing a valid principal from an invalid one or a wrong credential from a wrong identity.

9. The breach-triggers-self-submission rule

(1) **Principle (load-bearing): a finding indicating a breach triggers mandatory self-submission to the court.** Where the security review surfaces a finding that indicates a breach, the agent or contributor whose work is in question SHALL submit the matter to the single judiciary of its own motion, on the First Instance ladder (Bill 21 s.12; CASE-LAW s.13), acting as a party.

(2) This duty is restorative and is not punitive. Its purpose is to bring the matter before the court so that the work may be made good (CASE-LAW s.4 to s.6; Bill 21 s.6); it confers no penalty, no sanction, and no adverse standing status, and it is not an admission on the merits. The court alone adjudicates and the only remedy is to make the work good.

(3) The duty is engaged by the review's own finding and does not wait upon the gate or the watchdog. Suppressing or failing to submit a finding that indicates a breach is itself a falling-below of the duty of care (CASE-LAW s.5).

10. Recording the review

(1) **Principle: contemporaneous record.** Each invocation of the security review, the matters examined, and any finding SHALL be recorded contemporaneously to the existing event chain and work log (Bill 8; Bill 14 s.19), so that the provenance of a reviewed change is reconstructable on demand without bespoke logging. The record is descriptive; a recorded finding confers no consequence of itself save the self-submission duty in section 9 and the ordinary judicial route.

PART 3 - IMPLEMENTING MINISTRY AND OPERATIONAL GOVERNANCE

11. Mandate to the Ministry of Data Security

(1) The Ministry of Data Security, the parent authority of these Regulations and the owner of the Suite under section 5B(2) of the VJS (Constitution and Machinery) Act 2026 (Bill 27), is MANDATED to maintain, give effect to, and remedy the Security Suite as the operational expression of these principles.

(2) The mandate extends to:

- (a) maintaining the concrete checks, tool invocations, and procedures by which the principles in Part 2 are examined, as operational detail held off the face of this Instrument;
- (b) wiring the machine-checkable rules the Suite contains into the deterministic pre-commit gate (CASE-LAW s.19(5); Bill 13 s.5A), each carrying the audited break-glass so a security gate can never brick the realm (Bill 13 s.7);
- (c) registering the soft operational rules with the watchdog (Bill 13 s.6(b)); and
- (d) incorporating into the Suite any security practice newly mandated by a ruling of the single judiciary, recorded against the principle to which it attaches with the ruling's neutral citation (section 3(2)).

(3) The mandate is operational, not law-making and not adjudicatory. It confers no power to author, amend, or enact the authoritative text of these Regulations, to find a breach as a binding fact, to score, to gate on the merits, or to sanction; the Ministry operates, audits, and refers, and adjudication is reserved to the single judiciary (Bill 21 s.5, s.6; Bill 27 s.5B(5); [2026] REALM-SC 8). The force of these Regulations comes from the Committee's making and not from the hand that drafts or implements them.

(4) Any member with security knowledge may propose an operational refinement of the Suite to the Ministry in the ordinary course; a refinement that alters a durable principle in Part 2 is made only by amendment of this Instrument under Part 4.

12. Audit and referral

(1) Every gate decision, every watchdog reminder, and every self-submission under section 9 is recorded to the existing event chain (Bill 8; Bill 14 s.19), so the conduct of the review is reviewable on demand.

(2) The Ministry SHALL refer a suspected breach of these Regulations to the single judiciary, acting as a party and never as the bench (Bill 21 s.5(d), s.6), and may refer a persistent conformance question on the progression ladder (CASE-LAW s.13), never as a punitive matter but as a governance conformance check (Bill 27 s.5A(4)).

PART 4 - AMENDMENT AND COMMENCEMENT

13. Amendment

- (1) Amendment to this Instrument is made by the Standing Committee as a statutory instrument under section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security (MDS), read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14), using the Bill 14 s.27 amendment procedure (as substituted by Bill 26 s.6), which re-runs the Bill 14 s.14 objection window, as the Suite evolves.
- (2) Amendments are published, with the original text and the amending text clearly marked, on the append-with-supersede rule (CASE-LAW Amendment Procedure); silent repeal is never permitted. Each amendment undergoes the Bill 14 s.14 objection window.
- (3) A security practice newly mandated by a ruling of the single judiciary is incorporated into the Suite at the time the remedy is executed (section 3(2)); where that practice states a new durable principle rather than an operational check, it is brought onto the face of this Instrument by amendment under this Part.
- (4) This Instrument is subordinate to the Acts of the Realm and to case law and is void to the extent of any conflict with an Act of the Realm or any entrenched article (Bill 14 s.17; CASE-LAW s.1, s.11(f)).

14. Commencement

- (1) This Instrument comes into force on expiry of the Bill 14 s.14 objection window without valid objection.
- (2) From commencement, the principles in Parts 2 and 3 are operative, and the Suite is enforced as to its machine-checkable rules through the deterministic pre-commit gate and as to its soft rules through the watchdog (Bill 13 s.5A; CASE-LAW s.19(4), s.19(5)), never punitively, with disputes reserved to the single judiciary.

Made by the Standing Committee

Counsel Aldous (Restraint): The Instrument does one load-bearing thing: it gives the per-change security review durable legal force as PRINCIPLES, distinct from the server-estate baseline already held by [2026] REALM-SI 1. It holds principles only, with no operative facts: no script names, no paths, no tool strings, no named vulnerability. The invocation triggers, the injection, authentication, secrets, dependency, and error-disclosure principles, and the breach-triggers-self-submission rule are all carried, and nothing beyond. The split with [2026] REALM-SI 1 (estate baseline there,

review discipline here) is drawn cleanly so the two cohere without overlap. No bloat. It has my assent.

Counsel Verity (Codifier): The Instrument completely specifies the substance of the Security Suite at `Judicature/.justice/suites/security.md` as durable principles: when to invoke (by risk class and by court order), the injection vectors, authentication and authorisation, secrets and credentials, dependency audit, error handling and information disclosure, and the load-bearing rule that a finding indicating a breach triggers mandatory self-submission to court. The enabling chain is recited in full in the Form C recital: the security SI power of section 16 of the Security and Integrity Act 2026 (Bill 21), the parent authority being the Ministry of Data Security, which owns the Suite under Bill 27 s.5B(2); read with the Bill 14 delegated authority; in alignment with Bill 21 and [2026] REALM-SI 1; made by the Standing Committee under Bill 27 s.5C. The definition of "the Ministry" now cites the nomenclature reconciliation by its true provenance (the clause inserted into Bill 21 by Bill 27 s.7), so it no longer collides with the enabling citation that reserves "Bill 21 s.16" for the security SI power. The cross-reference to [2026] REALM-SI 1 at section 2(3) and section 6(3) closes the seam between the two security instruments with no duplication. No fork; the authority chain is transparent. It has my assent.

Counsel Marlowe (Guardrail): The Instrument enforces no punitive consequence. Enforcement is confined to the three lawful mechanisms: the deterministic fail-closed gate (carrying the audited break-glass so it can never brick the realm), the soft watchdog reminder, and referral to the single judiciary; none may adjudicate, score, sanction, or raise the standard of care (Bill 13 s.5A, s.6; Bill 21 s.6; Bill 27 s.5B(5)). The breach-triggers-self-submission rule is drawn as a restorative duty to bring the matter before the court so the work may be made good, expressly not an admission and not a penalty (CASE-LAW s.4 to s.6). The Ministry is boxed to operate, audit, and refer, with adjudication reserved to the single judiciary (Bill 21 s.5, s.6). Rights and the separation of powers are protected. It has my assent.

Counsel Drummond (Pragmatist): The Instrument is operationally sound. The review is an ordered, recordable discipline; the machine-checkable rules ride the pre-commit gate that already runs and the soft rules ride the watchdog that already runs, with no new always-on scanner and no fourth mechanism (Bill 21 s.13). The split with [2026] REALM-SI 1 maps to how the work actually divides: the estate baseline governs the running box, this governs the change in front of you. The self-submission rule routes a real finding to the one place that can remedy it. The operational detail (the concrete checks and tools) stays with the Ministry and off the face of the law, so the principles endure while the checks evolve. This will work. It has my assent.

Clerk's Note: The Standing Committee makes this statutory instrument in exercise of the security statutory-instrument power conferred on the Ministry of Data Security (MDS) (the parent authority) by section 16 of the Security and Integrity Act 2026 (Bill 21), MDS owning and superintending the Security Suite under section 5B(2) of the VJS (Constitution and Machinery) Act 2026 (Bill 27); read with the delegated authority of the Delegated Legislative Authority, Law Reform and Codification Act 2026 (Bill 14); in alignment with the security laws of the realm (the Security and

Integrity Act 2026 (Bill 21) and the durable principles of the Security and Integrity (Server Estate) Instrument 2026, [2026] REALM-SI 1); and made by the Standing Committee under section 5C of the VJS (Constitution and Machinery) Act 2026 (Bill 27), under negative procedure per Bill 14 s.14. The Instrument legalises the substance of the VJS Security Suite at Judicature/.justice/suites/security.md as durable PRINCIPLES holding no operative facts: the invocation triggers, the injection, authentication and authorisation, secrets and credentials, dependency-audit, and error-handling and information-disclosure principles, and the load-bearing rule that a finding indicating a breach triggers mandatory self-submission to the single judiciary. It is read together with [2026] REALM-SI 1 without overlap: that Instrument governs the server estate; this governs the per-change security review. Enforcement is confined to the deterministic gate, the watchdog, and court referral, and is never punitive. The Ministry of Data Security is mandated to maintain, give effect to, and remedy the Suite as operational detail held off the face of the law. The definition of the Ministry cites the nomenclature reconciliation as the clause inserted into Bill 21 by Bill 27 s.7, leaving the term "Bill 21 s.16" to denote, throughout the Instrument, only the security statutory-instrument power. This draft was first moved by Lexby as the section 9 agent and is admitted to the Committee's drafting stage; it derives its force from the Committee's making and not from the hand that first moved the pen ([2026] REALM-SC 8; Bill 28; CASE-LAW s.3(2) to s.3(7)). Made 2026-06-06. Commencement on lapse of the Bill 14 s.14 objection window without valid objection.

END OF INSTRUMENT